

Security Baseline

Owner: CISO. Applies to all systems that store or process customer data.

1. Encryption. Customer data must be encrypted at rest with AES-256 and in transit with TLS 1.2 or newer. Unencrypted storage of customer data is prohibited, including in backups, logs, and analytics exports.

2. Access control

Production access requires single sign-on with multi-factor authentication. Access is reviewed quarterly.

3. Vendors. Third-party vendors that process customer data should have a vendor risk assessment completed within the last 12 months before any data is shared. The CISO may grant a 60-day exception while an assessment is completed.

4. Logging. Security logs are retained for 12 months and must not contain passwords or full payment card numbers.